PROYECTO SGSI: INSTITUT EL MORELL

www.4geeks.com

Ivan Escamez

Sumario

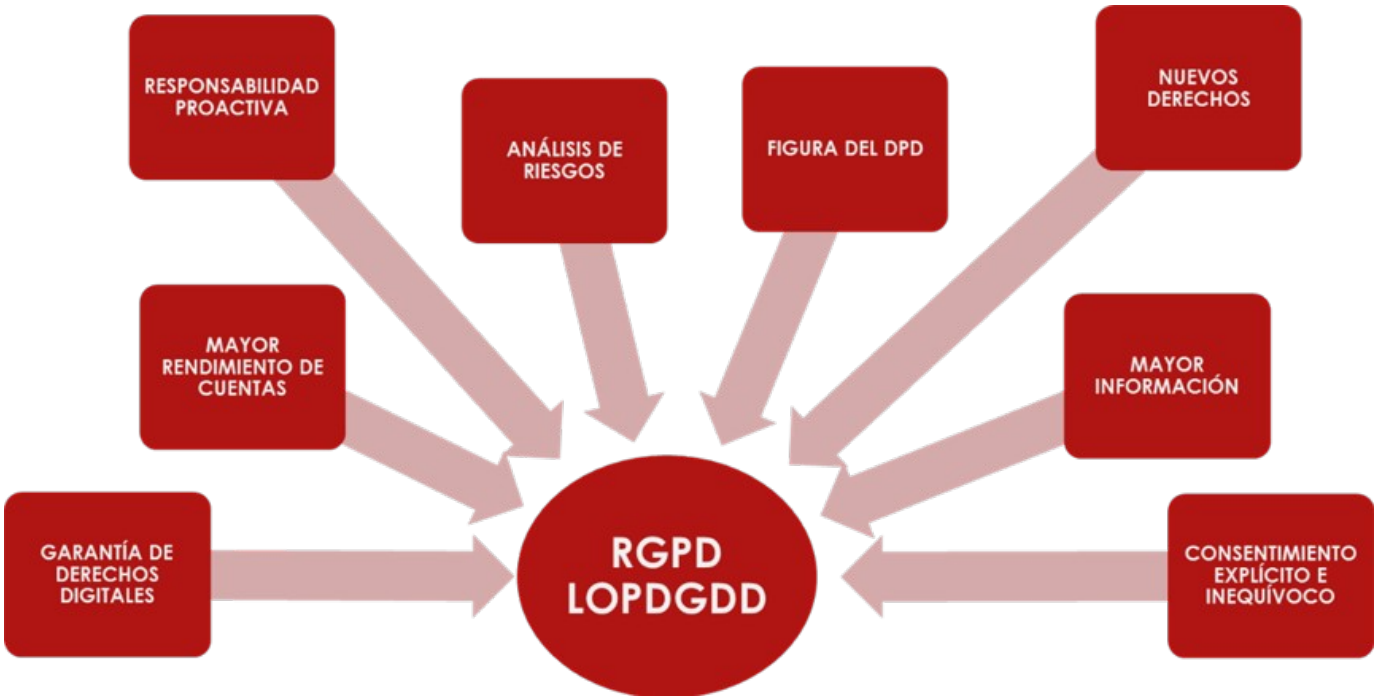
1. INTRODUCCIÓN....1
2. ALCANCE Y ACTIVOS....2
3. ANÁLISIS DE RIESGOS Y CONSECUENCIAS....3
3.1 Matriz de Riesgos....4
3.2 Consecuencias....5
4. GESTIÓN DE IDENTIDAD....6
5. POLÍTICAS Y PROCEDIMIENTOS....8
5.1 Políticas de Uso....8
5.2 Protocolo de Gestión de Incidentes....9
6. CLAVES Y CONCLUSIONES....10
ANEXO II: TABLA DE ACTIVOS....11
Anexo III: Formulario de incidencias....11

1. INTRODUCCIÓN

El **INS El Morell** es un centro público que debe garantizar la seguridad de la información académica bajo el **Esquema Nacional de Seguridad (ENS)**. Este documento establece las bases para proteger la confidencialidad, integridad y disponibilidad de los datos.

- **Compromiso:** La dirección del centro asume la seguridad de la información como una prioridad estratégica para el correcto funcionamiento .

- **Marco Legal:** Cumplimiento estricto del **RGPD** y la **LOPDGDD** para asegurar la **máxima protección de datos** de menores.

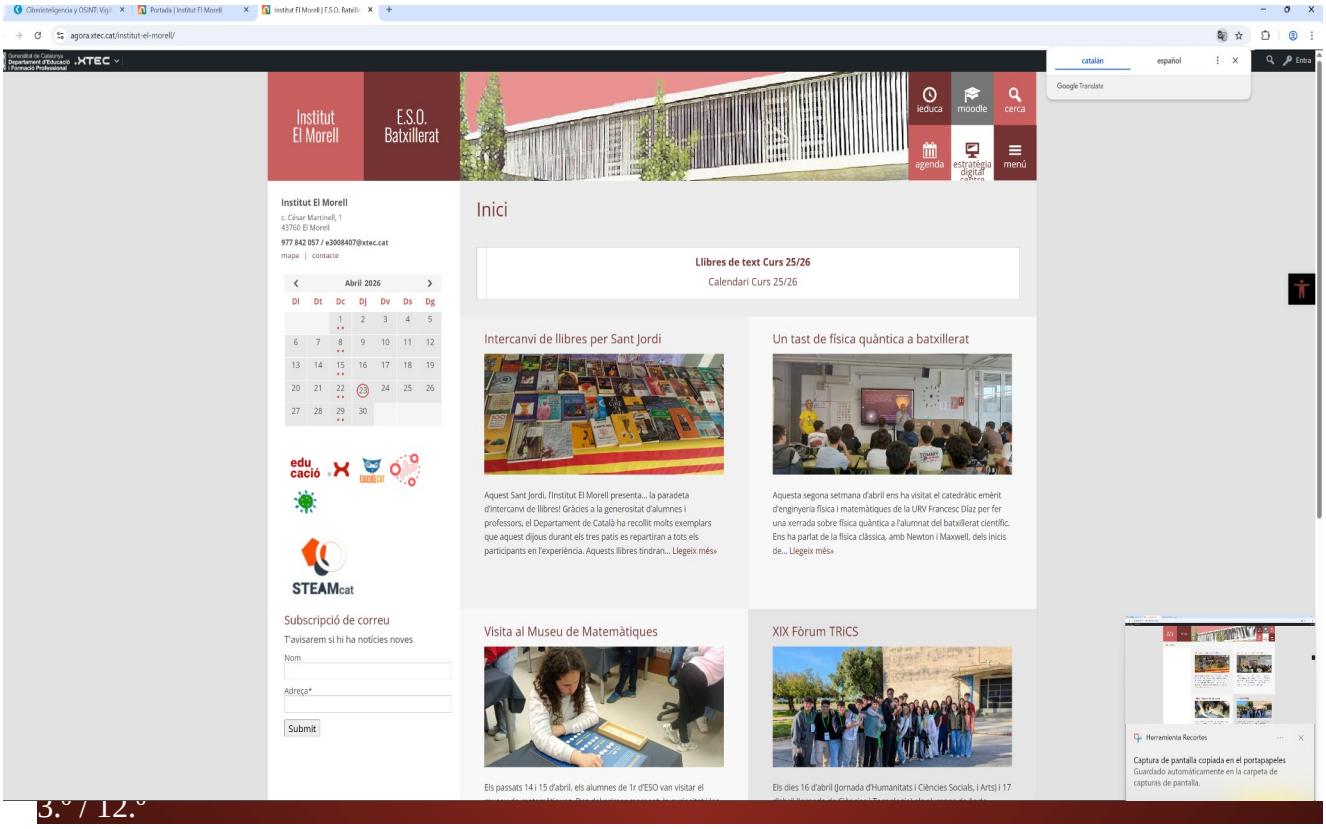


2. ALCANCE Y ACTIVOS

El sistema protege todos los activos digitales y físicos situados en el recinto del INS El Morell.

- **Activos Críticos:** Sistema **Esfer@** (Gestión de la Generalitat), Google Workspace for Education (@inselmorell.cat) y la plataforma Moodle.

- **Hardware:** Contamos con 4 racks de comunicaciones, 120 Chromebooks de alumnos y 60 portátiles de profesorado aproximadamente cada año suman o restan alumnos al centro.
- **Exclusiones:** Se excluye el servicio de comedor al no disponer de él. Se excluyen dispositivos personales no autorizados como teléfonos de alumnos



3. ANÁLISIS DE RIESGOS Y CONSECUENCIAS

3.1 Matriz de Riesgos

Activo	Amenaza	Impacto	Probabilidad	Nivel de Riesgo
Notas (Esfer@)	Alteración malintencionada	5	4	20 (Crítico)
Correo (Gmail)	Suplantación (Phishing)	4	4	16 (Alto)
Dispositivos	Robo físico en el centro	3	4	12 (Medio)

3.2 Consecuencias.

Si el riesgo se materializa, el INS El Morell podria enfrentar:

- **Consecuencias Administrativas: Sanciones de la Autoridad** Catalana de Protección de Datos (**APDCAT**) por la **exposición de datos sensibles** de menores.

- **Consecuencias Académicas:** Una alteración en **Esfer@ invalidaría** los expedientes de 2º de Bachillerato, impidiendo que los alumnos realicen la **Selectividad** a tiempo.

- **Consecuencias Reputacionales:** La **pérdida de confianza** de las familias del Morell y la **posible responsabilidad patrimonial de la Generalitat ante las demandas**.

4. GESTIÓN DE IDENTIDAD

Para mitigar los riesgos, se implementa una doble capa para contraseñas:

1. **Google Password Manager (Capa Docente):**

   - Sincronización segura de credenciales en el navegador Chrome.
   - Generación de claves robustas (mínimo 12 caracteres con símbolos).
   - Detección automática de contraseñas filtradas en la red.

2.KeePassXC:

- Uso de una "caja fuerte" local para las claves de **Esfer@**.

- Cifrado **AES-256**. La base de datos no sube a la nube; se queda en el PC de secretaría.

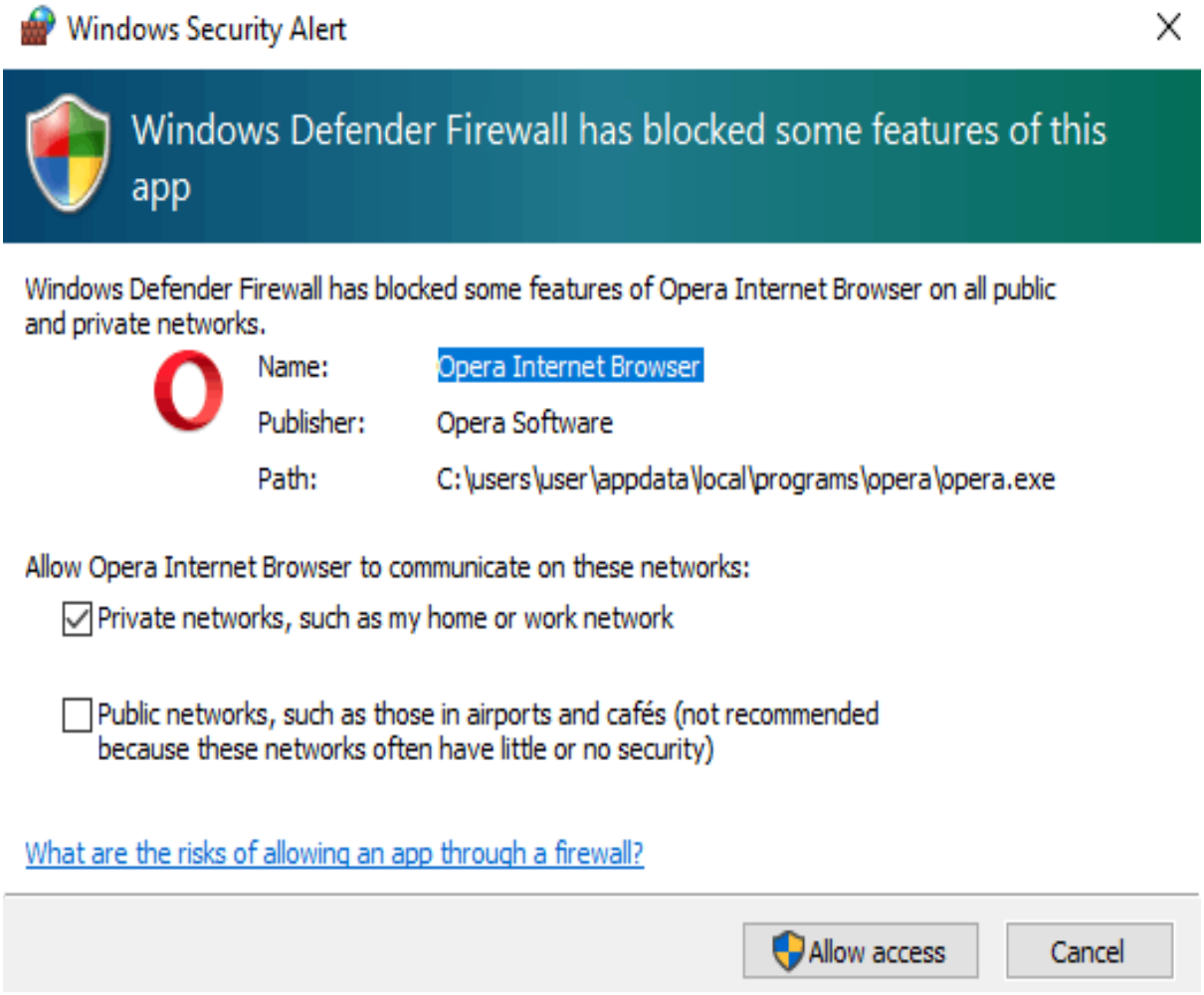
- Backup de la base de datos en un USB cifrado guardado en la caja fuerte física del instituto o en algun lugar donde nadie mas que el director o el equipo de trabajo pueda acceder.

5. POLÍTICAS Y PROCEDIMIENTOS

5.1 Políticas de Uso

- **Política de Pantalla Limpia:** Los administrativos deben bloquear el PC con las teclas (Win+L) al levantarse de su puesto.

- **Uso de Chromebooks:** Bloqueo de VPNs y extensiones de navegador que permitan evadir el firewall del centro.



5.2 Protocolo de Gestión de Incidentes

- **Detección:** Si se detecta un virus **(Ransomware)**, **no apagar el PC**,**se desconecta el cable de red inmediatamente.**

- **Contención:** El Coordinador Digital **aisla el segmento de red afectado** para que el **ataque no llegue** a secretaría y no se propague por los dispositivos o internet.

- **Recuperación 3-2-1:** Restauración desde la nube de Google y copias físicas externas **(fuera del edificio1 y otra en la caja fuerte)**.

6. CLAVES Y CONCLUSIONES

- ***ANEXO I:***
- ***Estas claves sirven para que cualquier miembro del equipo directivo o docente entienda los conceptos de seguridad utilizados en el SGSI.***

1. **MFA (Multi-Factor Authentication):** Sistema de seguridad que requiere **más de una forma de verificación** para acceder a una cuenta. En el INS El Morell, se utiliza **combinando la contraseña habitual con un código** enviado al dispositivo móvil del profesor.

2. **Encriptación** (**Cifrado**): Proceso de **convertir información o datos en un código secreto** para evitar el acceso no autorizado. Utilizamos el estándar AES-256 para **proteger la base de datos de contraseñas.**

3. **Ransomware**: Un tipo de programa malicioso (**malware**) que cifra los archivos de un ordenador y **exige el pago** de un rescate para liberarlos. Es la **amenaza más grave** para el instituto, ya que podría **bloquear el acceso** a los expedientes académicos.

4. **Esfer@: Plataforma oficial** del Departament d'Educació de la Generalitat de Catalunya. Es el **núcleo central de datos** donde **se gestionan:** las matrículas, expedientes, las actas de evaluación y notas finales.

5. **SGSI** (Sistema de **Gestión de Seguridad de la Información**): Conjunto de políticas, procedimientos y controles que el instituto aplica para **gestionar y proteger su información** de manera sistemática.

ANEXO II: TABLA DE ACTIVOS

(Listado de números de serie) Hay muchos que estan dentro de la institucion, los cuales pueden ser de diferentes aulas (25 alumnos + 1 profesor) 26 dispositivos por aula: informática, robótica…

Este es un ejemplo:

ID Activo	Dispositivo	Modelo	Ubicación	Nº de Serie (S/N)
MOR-CH001	Chromebook	ASUS C424	Carrito Aula 1	SN-2024-AM001
MOR-CH002	Chromebook	ASUS C424	Carrito Aula 2	SN-2024-AM002
MOR-CH003	Chromebook	ASUS C424	Carrito Aula 3	SN-2024-AM003
MOR-CH045	Chromebook	HP G8	Biblioteca	SN-2024-HP045
MOR-SRV01	Servidor	Dell PowerEdge	Rack Secretaría	SN-DELL-9923
MOR-LAP01	Chromebook	Lenovo L14	Sala Profes	

- **Anexo III: Formulario de incidencias.**
- ***A continuación esta el documento que los profesores deben tener a mano para saber cómo actuar y qué información dar ante un posible intruso/ataque.***

PROTOCOLO DE REPORTE DE INCIDENTES - INS EL MORELL

Instrucciones inmediatas:

1. **NO APAGUE EL EQUIPO.**
2. **DESCONECTE EL CABLE DE RED (ETHERNET) O DESACTIVE EL WI-FI.**
3. **AVISE AL COORDINADOR DIGITAL O A SECRETARÍA.**

Datos del incidente (rellenar por el profesor):

- **Nombre del docente:**
  _____
- **Fecha y hora de detección: ____ / ____ / ____ a las ____**
- **Dispositivo afectado (ID Activo):**
  _____
- **Descripción del problema marcar casilla adecuada:**
  - **[ ] No puedo acceder a mi cuenta de Google.**
  - **[ ] Han aparecido archivos con nombres extraños.**
  - **[ ] He recibido un correo pidiendo contraseñas (Phishing).**
  - **[ ] El ordenador muestra un mensaje de rescate o bloqueo.**
- **Observaciones adicionales:**
  _____